1. Senaryo Nedir?

Bu testte iki farklı senaryo üzerinde çalıştım: biri gerçek bir Modbus TCP saldırı trafiği, diğeri ise tamamen normal ve güvenli ağ trafiği. Amaç, aracın bu iki durumu birbirinden ayırt edip edemeyeceğini görmekti.

Saldırı senaryosunda, bir saldırganın fabrika ağına sızarak PLC cihazlarına yetkisiz yazma komutları gönderdiği ve aynı zamanda ağdaki tüm portları taradığı varsayıldı. Güvenli senaryoda ise sadece normal okuma komutları içeren trafik kullanıldı.

2. Ne Kullandık?

Veri Seti Kaynağı

Portekiz Coimbra Üniversitesi'nin siber güvenlik araştırma ekibi tarafından gerçek bir endüstriyel ortamda üretilen Modbus TCP SCADA veri setini kullandım. Bu veri seti, akademik bir makale için oluşturulmuş olup CRITIS 2018 konferansında yayımlanmıştır.

Veri Setinin İçeriği

- Gerçek IP adresleri: 172.27.224.251 (saldırgan) ve 172.27.224.250 (hedef PLC)
- Saldırı türleri: Modbus Query Flooding, MitM saldırısı, port tarama
- Normal trafik: FC 1, 2, 3, 4 okuma komutları
- Saldırı trafiği: FC 5, FC 15 yetkisiz yazma komutları

Kullandığım JSON Formatı

Uygulama JSON formatında veri aldığı için Wireshark ile PCAP dosyalarını JSON'a dönüştürdüm. Her paket şu alanları içeriyordu: kimlik numarası, zaman damgası, kaynak IP, hedef IP, protokol, port numarası ve Modbus komut kodu.

3. Araç Ne İnceledi?

Aracın Traffic Analysis modülü yüklenen JSON dosyasını iki farklı kurala göre inceledi:

Kural 1 — Modbus Anomali Tespiti

FC 5 (Write Single Coil) ve FC 15 (Write Multiple Coils) komutlarını arıyor. Bu komutlar normalde yetkili bir mühendis tarafından gönderilmesi gerekir. Saldırı senaryomuzda 172.27.224.251 IP'sinden bu komutlar sürekli geliyordu ve araç bunları anında tespit etti.

Kural 2 — Port Tarama Tespiti

Aynı IP adresinden belirli bir süre içinde 10'dan fazla farklı porta bağlantı denemesi yapılması durumunda bu bir port tarama girişimi olarak işaretleniyor. Saldırı senaryomuzda 172.27.224.100 IP'si 14 farklı porta bağlanmaya çalıştı.

Risk Hesaplama Motoru

Tehditler tespit edildikten sonra araç Monte Carlo simülasyonu ile risk dağılımını hesapladı. 2000 farklı senaryo çalıştırılarak P10 (iyimser), ortalama ve P90 (kötümser) değerleri belirlendi. Markov Zinciri ise saldırının 24 saat içinde nasıl ilerleyeceğini tahmin etti.

4. Test Sonuçları

İki senaryo arasındaki fark çok belirgin çıktı. Araç, saldırı trafiğini doğru şekilde tespit etti ve parametreler otomatik olarak güncellendi.

Parametre	Saldırı Senaryosu	Güvenli Senaryo
Tespit Edilen Tehdit	Modbus Anomaly + Port Scan	Yok
Beklenen Etki	9.5 / 10	3.0 / 10
Saldırı Olasılığı	%95	%20
Azaltma Etkinliği	%10	%80
Ortalama Risk Skoru	~81	~12
Ağ Haritası	HMI + PLC Kırmızı	Tüm Cihazlar Yeşil
Ele Geçirilme Süresi	~3 saat	Tehdit Yok

5. Bu Testten Ne Öğrendik?

- Araç, gerçek bir saldırı veri seti üzerinde doğru çalıştı — simüle edilmiş değil, gerçek akademik veri.
- FC 5 ve FC 15 komutları anında tespit edildi; bu Modbus protokolüne özel bir tespit yeteneği.
- Risk parametreleri otomatik güncellendi — kullanıcı müdahalesi gerekmedi.
- Güvenli trafik yüklendiğinde araç doğru şekilde 'tehdit yok' dedi ve risk skoru düştü.
- Sonuçlar karar vericilere somut bir zaman çerçevesi sunuyor: '3 saatiniz var, harekete geçin.'